

CVEs más relevantes de la semana

Del 11/07/2026 al 18/07/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-56372

Descripción: ImageMagick before 7.1.2-19 contains a heap buffer overflow vulnerability in the magnify operation that allows attackers to read out of bounds memory. An unrecognized magnify:method value triggers an out of bounds read, potentially exposing sensitive information or causing denial of service.

CVSS: 3.3 (LOW)

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-11



CVE-2026-10666

Descripción: `parse_ipv4()` in `subsys/net/ip/utils.c` (reached via `net_ipaddr_parse()` for strings of the form "a.b.c.d:port") copies the port substring into a fixed 17-byte stack buffer (`char ipaddr[NET_IPV4_ADDR_LEN + 1]`) using a length of `str_len - end - 1`, where `str_len` is the full, unbounded input length and `end` is only the (≤ 15 -byte) offset of the ':' delimiter. Because the destination size is never cons...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-07-12



CVE-2026-57830

Descripción: The Joomla extension Helix Ultimate is vulnerable to an unauthenticated arbitrary file deletion.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-40468

Descripción: Integer overflow vulnerability has been found in "builtin.c" program file of gawk. This issue may lead to memory exhaustion on the hosting operating system and could be used to overwrite gawk heap metadata and objects with attacker-controlled bytes. It affects gawk in versions 5.4.0 and below.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-40469

Descripción: Integer overflow vulnerability has been found in "builtin.c" program file of gawk (do_sub() routine). This issue could be used to overwrite gawk heap metadata and objects causing the program to crash. It affects 32-bit builds of gawk in versions 5.4.0 and below.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-13221

Descripción: Perl versions through 5.43.9 produce silently incorrect regular expression matches when an alternation of more than 65535 fixed string branches is compiled into a trie in Perl_study_chunk.

When such branches are combined into a trie, the delta between the first branch and the shared tail is stored in a 16-bit field. A branch count above 65535 overflows the field, and the trie's match decision ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-13



CVE-2026-58319

Descripción: Certain Apache Doris FE HTTP REST administrative APIs were accessible without proper authentication. An unauthenticated attacker with network access to the FE HTTP service could perform unauthorized administrative operations, potentially affecting cluster integrity and availability and leading to cluster instability or denial of service.

This issue affects Apache Doris versions prior to 3.1.0...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-62390

Descripción: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Apache Kylin. A backend API refreshing table catalog may cause the injection to the generated SQL.

This issue affects Apache Kylin: from 4 through 5.0.3.

Users are recommended to upgrade to version 5.0.4, which fixes the issue.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-62392

Descripción: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in Apache Kylin. A backend API may bring job config parameters to OS command line.

This issue affects Apache Kylin: from 4 through 5.0.3.

Users are recommended to upgrade to version 5.0.4, which fixes the issue.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-59836

Descripción: A improper certificate validation vulnerability in Fortinet FortiClientEMS 7.4.3 through 7.4.5, FortiClientEMS 7.4.0 through 7.4.1, FortiClientEMS 7.2 all versions may allow attacker to information disclosure via <insert attack vector here>

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-295

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-49164

Descripción: Heap-based buffer overflow in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-50694

Descripción: Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an unauthorized attacker to execute code over a network.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-54433

Descripción: In Roundcube Webmail before 1.6.17 and 1.7.x before 1.7.2, there is Stored Cross-Site Scripting (XSS) via a crafted plain-text email message. The attacker-controlled JavaScript executes within the victim's authenticated session simply by opening or previewing the message (zero-click).

CVSS: 7.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-56164

Descripción: Missing authentication for critical function in Microsoft Office SharePoint allows an unauthorized attacker to elevate privileges over a network.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-57089

Descripción: Use after free in Windows SMB Server Network Transport Driver (srvnet.sys) allows an unauthorized attacker to execute code over a network.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-57090

Descripción: Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-58594

Descripción: Integer overflow or wraparound in Windows RDP allows an unauthorized attacker to execute code over a network.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-58617

Descripción: Improper access control in Microsoft 365 Copilot for iOS allows an unauthorized attacker to elevate privileges over a network.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-45063

Descripción: Symfony is a PHP framework for web and console applications and a set of reusable PHP components. Prior to 5.4.52, 6.4.40, 7.4.12, and 8.0.12, X509Authenticator extracts the user identifier from `$_SERVER['SSL_CLIENT_S_DN']` with an unanchored regex that matches `emailAddress=` anywhere in the distinguished name, allowing an attacker with a trusted certificate containing `emailAddress=victim` inside ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-45069

Descripción: Symfony is a PHP framework for web and console applications and a set of reusable PHP components. Prior to 6.4.40, 7.4.12, and 8.0.12, `OidcTokenHandler::verifyClaims()` registered audience (aud), issuer (iss), and expiry (exp) checkers but did not pass the mandatory claims list to `ClaimCheckerManager::check()`, so a validly signed JWT that omitted those claims could pass verification. This issue ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-47767

Descripción: Symfony is a PHP framework for web and console applications and a set of reusable PHP components. From 5.4.46 until 5.4.52, 6.4.40, 7.4.12, and 8.0.12, the CVE-2024-50340 fix gated runtime argv parsing on `empty($_GET)`, but `parse_str()` and the web SAPI can disagree, allowing a crafted query string to leave `$_GET` empty while `$_SERVER['argv']` still carries attacker-controlled `--env` or `--no-debug` f...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-436

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-47984

Descripción: Adobe Commerce is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and write access. Exploitation of this issue does not require user interaction.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-47988

Descripción: Adobe Commerce is affected by an Incorrect Authorization vulnerability that could result in a Security feature bypass. An attacker could leverage this vulnerability to bypass security measures and gain unauthorized read and write access. Exploitation of this issue does not require user interaction.

CVSS: 8.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48356

Descripción: Adobe Commerce is affected by an Unrestricted Upload of File with Dangerous Type vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user inte...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:L

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48358

Descripción: Adobe Commerce is affected by an Improper Encoding or Escaping of Output vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-116

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-24227

Descripción: NVIDIA TensorRT for contains a vulnerability where a user might cause a deserialization of untrusted data. A successful exploit of this vulnerability might lead to code execution.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48284

Descripción: ColdFusion is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48319

Descripción: ColdFusion is affected by an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48320

Descripción: ColdFusion is affected by a reflected Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48321

Descripción: ColdFusion is affected by an Incorrect Authorization vulnerability that could result in privilege escalation. An attacker could leverage this vulnerability to gain unauthorized read and write access. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48322

Descripción: ColdFusion is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48324

Descripción: ColdFusion is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-46633

Descripción: Twig is a template language for PHP. Prior to 3.26.0, `Compiler::string()` does not escape single quotes when a template name from a `{% use %}` tag is placed inside a PHP single-quoted string literal, allowing a crafted template name to terminate the string and inject arbitrary PHP expressions into the compiled cache file. This issue is fixed in version 3.26.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-46634

Descripción: Twig is a template language for PHP. From 3.9.0 until 3.26.0, `template_from_string()` compiles an inner template under a synthesized `__string_template__<hash>` name that can fall outside a `SourcePolicyInterface` sandbox decision, allowing a sandboxed template that can call `template_from_string` and `include` to render an inner template without security policy enforcement. This issue is fixed in versi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48334

Descripción: Illustrator is affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue requires user interaction in that a victim must open a malicious file. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48805

Descripción: Twig is a template language for PHP. Prior to 3.27.0, deprecated internal wrappers in `src/Resources/core.php` do not forward the current sandbox state to `CoreExtension::checkArrow()`, `arraySome()`, and `arrayEvery()`, allowing legacy calls such as `twig_array_some()`, `twig_array_every()`, and `twig_check_arrow_in_sandbox()` to bypass sandbox callable restrictions. This issue is fixed in version 3.27.0.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48806

Descripción: Twig is a template language for PHP. Prior to 3.27.0, ArrayExpression does not guard dynamic mapping keys that are coerced to strings, allowing PHP to invoke `__toString()` on a Stringable object used as a mapping key without calling `SandboxExtension::ensureToStringAllowed()`. This issue is fixed in version 3.27.0.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-48807

Descripción: Twig is a template language for PHP. Prior to 3.27.0, the sandbox `__toString()` checks do not fully cover Traversable values passed to join and replace filters or operands evaluated by the in and not in operators, allowing contained Stringable objects to be coerced to strings without consulting the sandbox policy. This issue is fixed in version 3.27.0.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-07-14



CVE-2026-56398

Descripción: Open WebUI before 0.9.5 contains a stored cross-site scripting vulnerability in the OAuth authentication flow where the picture claim URL MIME type is inferred from file extension rather than Content-Type header, allowing SVG files to bypass the profile image validator and be stored as data URIs. Authenticated users who visit the profile image endpoint receive attacker-controlled SVG content wi...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-56400

Descripción: open-webui before 0.3.14 contains a cross-origin resource sharing misconfiguration allowing arbitrary origins with `allow_origins=*` and authenticated requests to the `/api/v1/functions` endpoint. Attackers can execute arbitrary code on the openwebui instance by crafting malicious cross-site requests from attacker-controlled websites when an admin user visits them.

CVSS: 8.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-613

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-54052

Descripción: n8n-MCP is an MCP server that provides AI assistants access to n8n node documentation, properties, and operations. Prior to 2.56.1, in HTTP mode with multi-tenancy enabled through `ENABLE_MULTI_TENANT=true`, n8n-mcp's local workflow version history backups were not isolated per tenant, allowing an authenticated tenant to read workflow version snapshots belonging to other tenants and delete or des...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-07-15



CVE-2026-56453

Descripción: HCL DFXAnalytics is affected by an Account Takeover via Response Manipulation vulnerability. A remote attacker can intercept and alter the contents of the server's HTTP responses before they reach the client application, allowing them to manipulate the authentication or authorization logic to bypass controls and gain unauthorized access to targeted user accounts.

CVSS: 5.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:L/A:L

Tipo: CWE-294

Tecnología: No especificado

Publicado el: 2026-07-16



CVE-2026-44596

Descripción: Yamcs is a mission control framework. Prior to 5.12.7, the authentication endpoint POST /auth/token in yamcs-core, handled by yamcs-core/src/main/java/org/yamcs/http/auth/AuthHandler.java, lacked any rate limiting, account lockout, or failed-attempt throttling, so an unauthenticated remote attacker could perform unlimited password-guessing attempts against any user account, significantly increa...

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-07-16



CVE-2026-14956

Descripción: The Bricksforge plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 3.1.8.6. This is due to improper validation of the fieldIds parameter in the Pro Forms registration action, which allows attacker-supplied field IDs to be added to the trusted form-field whitelist. This makes it possible for unauthenticated attackers to register a new administrator a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-12692

Descripción: Unverified password change vulnerability in Vimesoft Inc. Enterprise Video Platform allows Authentication Bypass.

This issue affects Enterprise Video Platform: from 3.11.0.0 before 3.25.0.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-620

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8297

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Gis Informatics Engineering Consulting Laboratory R&D and Software Services Inc. GisLab Laboratory Management System allows SQL Injection.

This issue affects GisLab Laboratory Management System: from 1.4.03 through 08072026.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-9103

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 could allow a remote attacker to gain unauthorized access due to improper authentication in the /api/v1/login/auto_login endpoint. The endpoint issues long-lived superuser bearer tokens without requiring authentication when the AUTO_LOGIN configuration is enabled (enabled by default), which may allow an unauthenticated network attacker to obtain full admini...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-9135

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 Langflow versions up to 1.9.2 (commit 94981c443d4918517b9e8163d70fc598dc33a32d) contain a code injection vulnerability in the Policies component's ToolGuard integration that bypasses the `allow_custom_components=false` security control. The vulnerability exists because the validation mechanism only checks the main component source code in `node_template["code"]...`

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-15091

Descripción: IBM Engineering AI Hub 1.0.0, 1.1.0, and 1.2.0 could allow a remote attacker to execute arbitrary scripts due to improper neutralization of input during web page generation.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8476

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 contain a critical remote code execution vulnerability in the disk-based caching mechanism. The AsyncDiskCache class uses Python's unsafe pickle.loads() function to deserialize cached objects from disk without validation, integrity verification, or authentication, enabling arbitrary code execution when malicious pickle payloads are processed. Attackers who ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8481

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 contain a critical remote code execution vulnerability in the code validation API endpoint. The POST /api/v1/validate/code endpoint accepts user-supplied Python code and executes it directly using Python's built-in exec() function without sandboxing, input validation, or privilege restrictions, enabling any authenticated user to execute arbitrary system com...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8635

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 allows authenticated users to escalate privileges to superuser by directly manipulating the database, execute arbitrary system commands, and achieve full system compromise with Langflow service permissions.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-8859

Descripción: IBM Langflow OSS 1.0.0 through 1.10.0 Langflow could allow an attacker to write arbitrary files to unintended locations due to improper input validation in the APIRequest component. A path traversal vulnerability exists when the "Save to File" feature is enabled, where filenames extracted from HTTP response Content-Disposition headers are not sanitized before being joined to the temporary direc...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-17



CVE-2026-13446

Descripción: IBM Langflow OSS 1.0.0 through 1.10.1 contains hard-coded credentials, such as a password or cryptographic key, which it uses for its own inbound authentication, outbound communication to external components, or encryption of internal data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-07-17



Resumen del Reporte

CVEs analizados: 54

Promedio CVSS: 8.73

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat 🐱

